Practical - 10

Practical Title: Secure Login/Logout with Sessions, Role-Based Access, Timeout, and Remember-Me Token

Problem Definition: Develop secure login and logout functionality using PHP sessions. Verify password using password_verify(), regenerate session ID after login, restrict dashboard access, implement role-based redirection, session timeout, and optional secure remember-me token.

Theory :

1. Are sessions started and destroyed securely?
Yes. session_regenerate_id(true) is used after a successful login to prevent session fixation. On logout, session_unset() and session_destroy() are used, the session cookie is deleted, and the user is redirected to the login page.

2. Is password_verify() used correctly?
Yes. The user is found by email using a prepared statement, and the entered password is compared with the stored hash using password_verify(). Passwords or hashes are never compared directly using == , and a general message "Invalid email or password" is shown on failure.

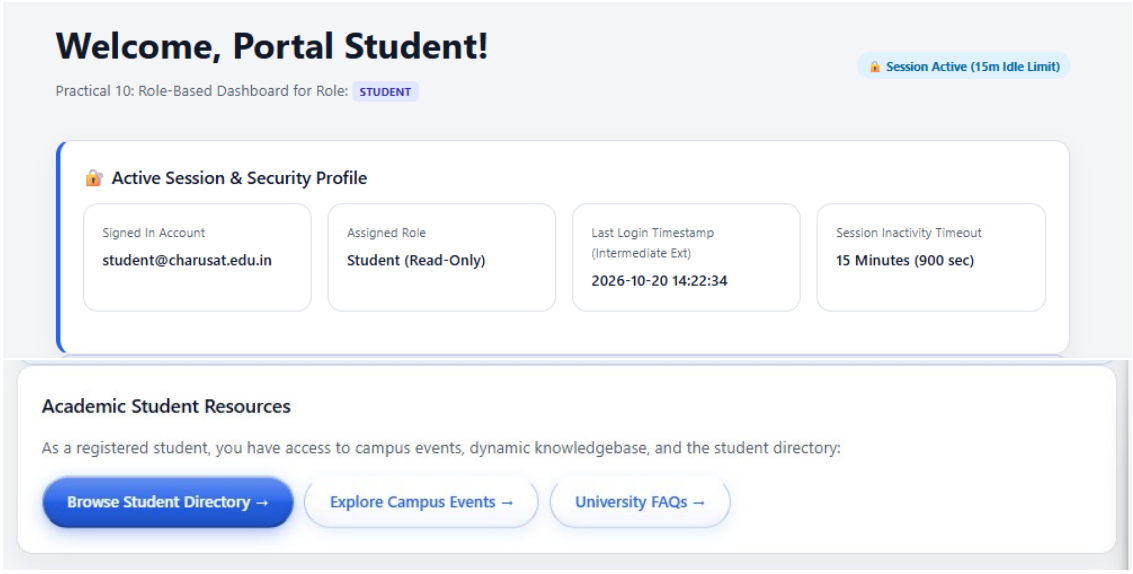
3. Is unauthorized dashboard access blocked?
Yes. Every dashboard page checks whether $_SESSION['user_id'] is set. If the user is not logged in, the user is redirected to the login page and exit() stops the remaining code from running.

4. Is session timeout implemented?
Yes. The time of the last activity is saved in $_SESSION['last_activity']. On every request, if the difference between the current time and the last activity is more than the allowed time (for example 30 minutes), the session is destroyed and the user is redirected to the login page with a timeout message.

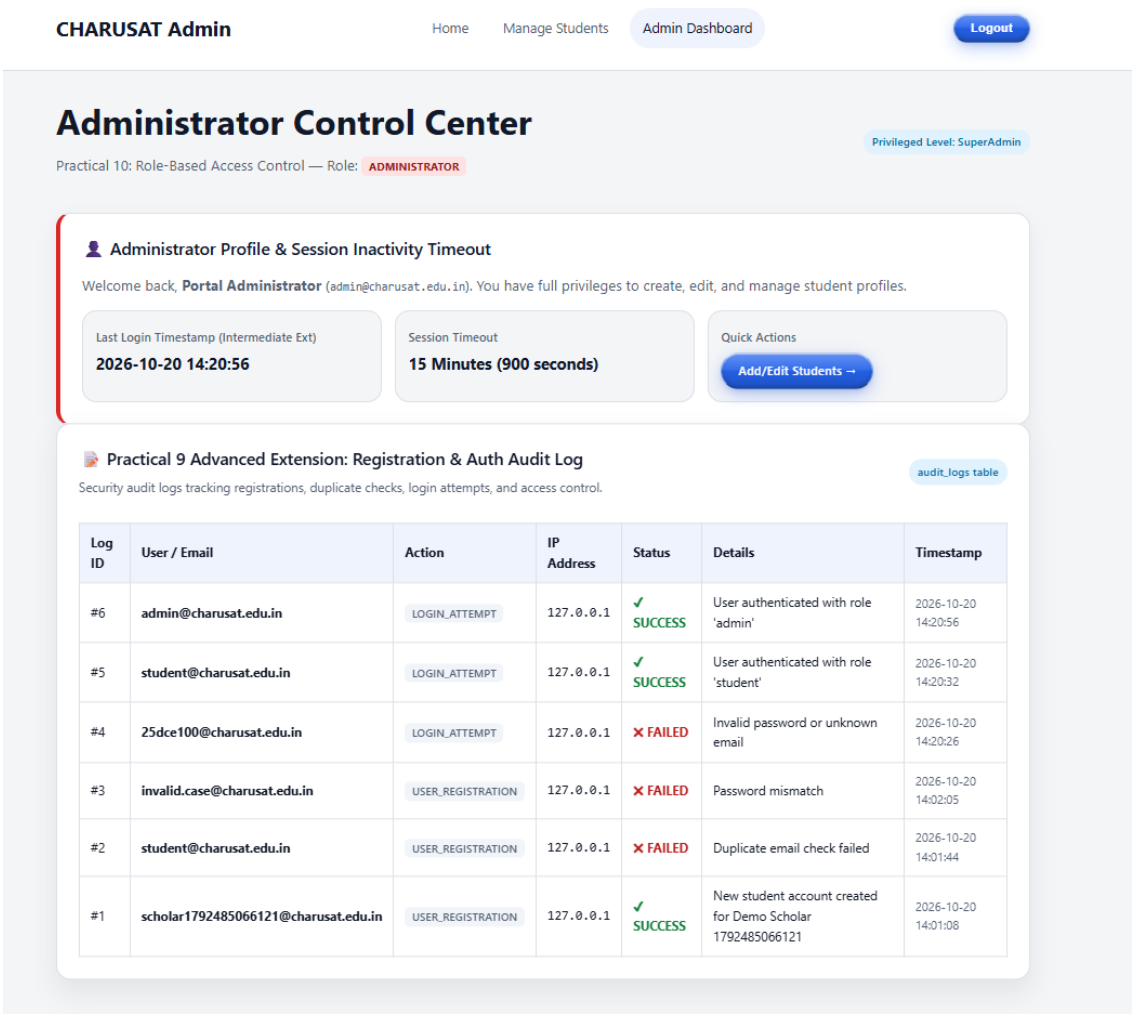
5. Are admin and student users redirected to appropriate dashboards?
Yes. The role of the user is stored in the session after login. Admin users are redirected to the admin dashboard and student users are redirected to the student dashboard. Admin pages also check that the role is admin, so a student cannot open them.

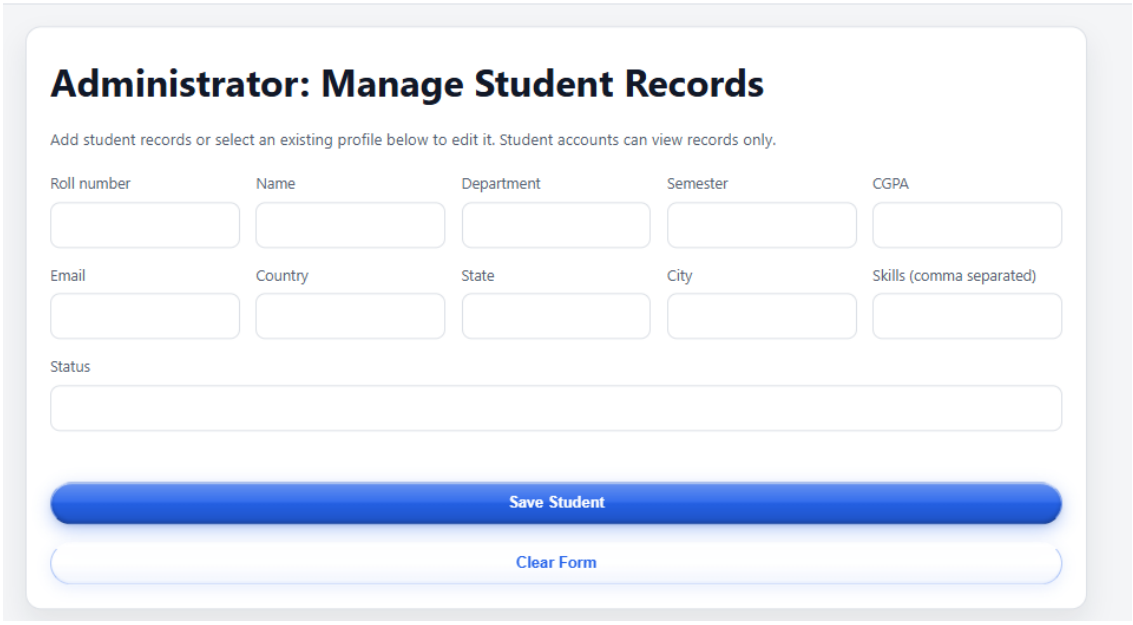
Evidence of Work (Screenshots):

Student login :-

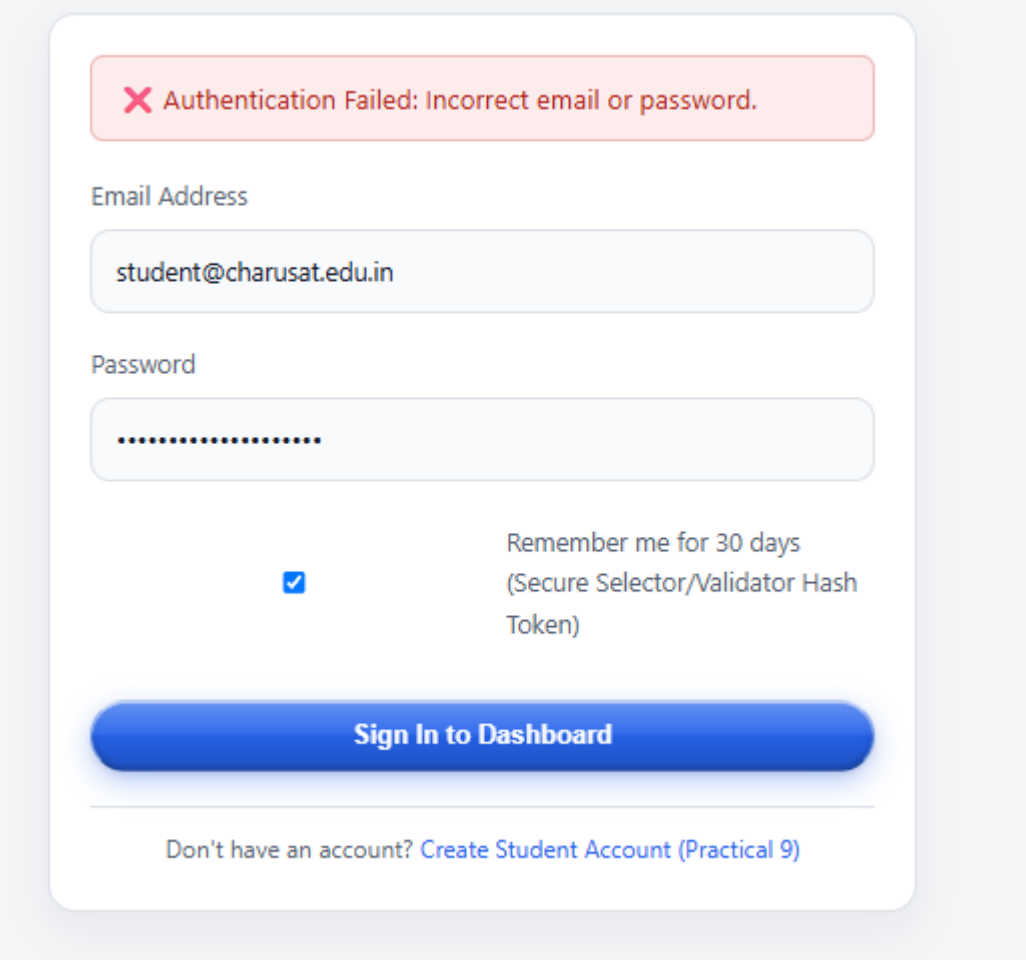


Password Mismatch error:


CHARUSAT Admin
Home
Manage Students
Admin Dashboard
Logout
Administrator Control Center
Privileged Level: SuperAdmin
Practical 10: Role-Based Access Control — Role: ADMINISTRATOR
Administrator Profile & Session Inactivity Timeout
Welcome back, Portal Administrator (admin@charusat.edu.in). You have full privileges to create, edit, and manage student profiles.
Last Login Timestamp (Intermediate Ext)
2026-10-20 14:20:56
Session Timeout
15 Minutes (900 seconds)
Quick Actions
Add/Edit Students →
Practical 9 Advanced Extension: Registration & Auth Audit Log
audit_logs table
Security audit logs tracking registrations, duplicate checks, login attempts, and access control.
Log ID
User / Email
Action
IP Address
Status
Details
Timestamp
#6
admin@charusat.edu.in
LOGIN_ATTEMPT
127.0.0.1
✓ SUCCESS
User authenticated with role 'admin'
2026-10-20 14:20:56
#5
student@charusat.edu.in
LOGIN_ATTEMPT
127.0.0.1
✓ SUCCESS
User authenticated with role 'student'
2026-10-20 14:20:32
#4
25dce100@charusat.edu.in
LOGIN_ATTEMPT
127.0.0.1
✕ FAILED
Invalid password or unknown email
2026-10-20 14:20:26
#3
invalid.case@charusat.edu.in
USER_REGISTRATION
127.0.0.1
✕ FAILED
Password mismatch
2026-10-20 14:02:05
#2
student@charusat.edu.in
USER_REGISTRATION
127.0.0.1
✕ FAILED
Duplicate email check failed
2026-10-20 14:01:44
#1
scholar1792485066121@charusat.edu.in
USER_REGISTRATION
127.0.0.1
✓ SUCCESS
New student account created for Demo Scholar 1792485066121
2026-10-20 14:01:08


Administrator: Manage Student Records
Add student records or select an existing profile below to edit it. Student accounts can view records only.
Roll number
Name
Department
Semester
CGPA
Email
Country
State
City
Skills (comma separated)
Status
Save Student
Clear Form

Wrong Login Details:



Repository Link :-
https://github.com/meet-3834/Student-Hub/tree/main/FINAL%20Submission

H. Learning Outcomes:
I am able to implement secure user registration following basic web security practices.

Faculty Remarks: (Keep this blank for faculty)